Permissions and roles management

🛡️ 1. Role-Based Access Control (RBAC) Framework

- **Custom Roles**: Allow admin to define roles tailored to organizational hierarchy or projects. Each role bundles specific permissions for modules and actions.
- **Role Templates**: Provide predefined templates to speed up setup and maintain consistency. Suggested templates:
    - **Super Admin**: Full access across all modules (user management, settings, system logs).
    - **HR Manager**: Access to employee records, performance data, leave requests, onboarding/offboarding modules.
    - **Recruiter**: Manage job postings, candidate pipelines, interview scheduling—but no payroll or system config.
    - **Finance/Payroll**: Handle payroll processing, salary data, benefits, expense tracking—no candidate or performance access.
    - **Viewer**: Read-only access to selected modules (e.g., org chart, reports), but cannot make changes.

⚙️ 2. Granular Module-Wise Permissions

Support permission settings at multiple levels:

1. **Module-Level** (e.g., Employee, Recruitment, Payroll, Reports).
2. **Action-Level** within each module (Create, Read, Update, Delete, Export).
3. **Field-Level / Record-Level** (optional for sensitive data).

Example:

- HR Manager: Create/update employee records, but cannot delete.
- Recruiter: Can view resumes and candidate notes but cannot edit HR templates.
- Finance: Access payroll module full CRUD, but read-only access to employee basic info.

- Viewer: Can only read employee profiles and view org level reports.

✅ 3. Least Privilege & Just-in-Time (JIT) Access

- **Least Privilege**: Users receive only the permissions necessary for their role stackby.com+2linkedin.com+2zoho.com+2stackby.com+1help.hrpartner.io+1.
- **JIT Access**: Elevated rights (e.g., delete employee record, run payroll) are time-limited — assigned only when needed and automatically revoked after the task is completed cloudeagle.ai.

🔄 4. Permission Lifecycle Management (Provisioning & De-provisioning)

- **Automated Workflow**: Integrate with HRIS to automatically provision access when new employees onboard and revoke upon exit.
- **Self-Service Requests**: Users request elevated access through approval workflows. Admins can approve, modify, and set expiration.
- **Audit Trails**: Log every access change with user, timestamp, approver, and reason. Regular reporting enhances visibility vertice.one+1stackby.com+1.

🌀 5. Regular Reviews & Access Audits

- **Scheduled Audits**: Monthly quick checks and quarterly deep audits ensure no overprivileged or stale accounts (especially for high-privilege roles) bettercloud.com+8cloudeagle.ai+8vertice.one+8.
- **Access Analytics**: Reports on role assignments vs activity trends to detect unused privileges or anomalies reddit.com+9vertice.one+9linkedin.com+9.

🔐 6. Strong Authentication & Security Coverage

- **MFA for Admins**: Super Admin and privileged roles protected with Multi-Factor Authentication help.jazzhr.com.
- **SSO Integration**: Support Single Sign-On providers (e.g., SAML, OAuth) for centralized identity management.

- **Privileged Session Handling**: Enforce timeouts, separate admin sessions, and enhanced monitoring help.hrpartner.io.

📝 7. Role Templates & Custom Role Creation

- **Prebuilt Templates**: Include the five recommended roles for fast onboarding.
- **Custom Role Builder**:
  - Select modules and permitted actions.
  - Optionally restrict by department, location, employee group.
  - Save custom roles and reuse across the organization (e.g., "Engineering Manager").
- **Template Copying**: Base custom roles on existing templates and tweak further.

📍 8. Contextual & Data-Level Restrictions

- **Scope by Entity**: Limit module access based on department, location, or business unit.
- **Record Ownership Flags**: e.g., Recruiter sees only their assigned candidates.
- **Time Window Permissions**: e.g., Payroll team can edit payroll only during designated pay cycle.

🧪 9. Audit Logging and Monitoring

- **Comprehensive Logs**: Track logins, failed attempts, permission changes, data access events.
- **Alerts**: Trigger notifications for unusual behaviors (e.g., sudden mass export).
- **Analytics Dashboard**: Visualize access patterns, inactive users, and anomalies over time docs.oracle.com+3stackby.com+3help.sap.com+3linkedin.com+1zoho.com+1.

🧩 10. Integration & API Provisioning

- **HRIS Sync**: Automatically sync user data, roles, and departments from HR master data.
- **Provisioning APIs**: For identity management, support SCIM or custom API integration.
- **On-Demand Elevation**: Programmatically request and retract elevated permission with audit record.

🛠️ 11. User Experience & Operational Usability

- **Clear Role Descriptions**: Admin UI includes role previews detailing module and action access.
- **Permission Simulator**: "What can this user do?" button for admins to validate role configuration.
- **Access Request Portal**: Users self-serve access requests with admin approval workflow; trackable and logged.
- **Helper Documentation**: Help icons explain each permission's impact in admin settings.

🛡️ Bonus: Security & Compliance Highlights

- **Zero Trust Architecture**: Validate every request, enforce MFA and least privilege .
- **Compliance Ready**: Access logs, audit trails, consent records, and data encryption support GDPR, SOC 2, HIPAA.
- **Shadow IT Detection**: Identify unused access, dormant accounts, and chance to remove unused privileges .

✅ Executive Summary

1. Define **RBAC model** with robust, module/action granularity.
2. Provide role templates and allow **custom roles** for flexibility.
3. Enforce **least privilege** and **time-limited elevated access**.
4. Automate provisioning/de-provisioning via HRIS or APIs.

5. Implement **scheduled audits**, logging, and access change tracking.
6. Secure high-risk access with **MFA** and **SSO**; monitor sessions.
7. Support **scope-based permissions** and contextual restrictions.
8. Offer a user-friendly admin panel with simulations and request workflows.
9. Maintain logs and analytics for **security, compliance, and anomaly detection**.

🔗 **Suggested Action Items**

- Finalize scope of modules & actions for permission control.
- Build super admin panel UI with templated roles, custom role creator, and permission simulator.
- Develop workflow for permission requests and approvals.
- Integrate with HRIS for provisioning and de-provisioning.
- Implement comprehensive logging and scheduling for periodic audits.
- Secure admin portal with MFA, SSO, and session monitoring.